

Ruben Apablaza Muñoz

PIPE

PDCA ISO27001

SGSI SMART



SGSI

Sistema de Gestión de la
Seguridad de la Información



- OZone -

Contenido

Introducción	2
1. ¿Qué es SGSI?	3
2. ¿Qué es PDCA?	4
3. ¿Qué es ISO 27.001?	5
4. ¿Qué es IEC?	5
5. ¿Por qué el SGSI es el PDCA?	6
6. Plan (Planificar)	9
7. DO (Hacer)	12
8. Check (Verificar)	14
9. Act (Actuar)	16
10. El ciclo cerrado	19
Conclusión	20

Introducción

¿Tienes la responsabilidad o el desafío de diseñar e implementar un Sistema de Gestión de Seguridad de la Información (SGSI)?

En este documento, Pipe aborda de forma clara, pragmática y directa la relación fundamental entre el ciclo de mejora continua **PDCA** (*Plan-Do-Check-Act*), el estándar internacional **ISO/IEC 27001** y la construcción de un SGSI eficiente.

A través de la explicación de cada una de las fases del ciclo PDCA aplicadas a la ciberseguridad, se presenta un caso de estudio práctico (Clínica Jaguar Salud). Este escenario permite aterrizar los conceptos teóricos a un entorno dinámico y real, facilitando la comprensión de cómo opera esta metodología en el día a día de una empresa u organización.

La implementación de un SGSI no está destinada únicamente a aquellas entidades que buscan una certificación formal para demostrar conformidad normativa y proyectar confianza a sus clientes y partes interesadas; representa, ante todo, un conjunto de buenas prácticas esenciales para resguardar los activos de información estratégicos, independientemente de la meta de certificación.

Conscientes de que la literatura sobre auditoría y normativas de seguridad suele ser densa y compleja, esta guía sintetiza los elementos clave desde una perspectiva accesible, amigable y estructurada. Su propósito es servir como una hoja de ruta conceptual y operativa para comprender los pilares de un SGSI y el porqué de la estructura de la norma ISO/IEC 27001.

1. ¿Qué es SGSI?

Sistema de **G**estión de **S**eguridad de la **I**nformación.

Es un marco de trabajo formal que permite a una organización

1. Planificar
2. Implementar
3. Supervisar
4. Mejorar

la seguridad de la información de forma oportuna.

¿Para qué sirve?

- **Proteger activos**

Resguarda datos confidenciales, sistemas e infraestructura frente a amenazas e incidentes.

- **Gestionar riesgos**

Identifica vulnerabilidades y define controles de seguridad proporcionales al riesgo.

- **Garantizar la triada CIA**

- **Confidencialidad:** Solo el personal autorizado accede a los datos.
- **Integridad:** La información se mantiene exacta y no es alterada sin permiso.
- **Disponibilidad:** Los datos están accesibles cuando se necesitan.

Estándar principal

La norma internacional de referencia para la implementación de un SGSI es la ISO/IEC 27.001

2. ¿Qué es PDCA?

También conocido como **Ciclo de Deming**¹, es una metodología de 4 pasos para la mejora continua de **CUALQUIER** proceso o sistema (no es exclusivo de ciberseguridad).

Las siglas son:

- **P (Plan / Planificar):** Defines qué vas a hacer, cómo y con qué objetivos.
- **D (Do / Hacer):** Implementas y ejecutas lo que planificaste.
- **C (Check / Verificar):** Mides y revisas si los resultados fueron los esperados.
- **A (Act / Actuar):** Corrige los errores, ajustas lo que falló y reinicias el ciclo mejorado.

En resumen:

Es un **bucle infinito** de:

Planear > Hacer > Revisar > Mejorar.



¹ El ciclo Deming: en qué consiste y cómo ayuda en la gestión y mejora de procesos. <https://www.eurofins-environment.es/es/el-ciclo-deming-que-consiste-y-como-ayuda-gestion-procesos/>

3. ¿Qué es ISO 27.001?

La **ISO 27001** es la **norma internacional** creada por la IEC que define los requisitos para crear, implementar y mantener un **SGSI** (Sistema de Gestión de Seguridad de la Información).

Es decir:

- **Es un estándar:** La guía oficial mundial de ciberseguridad.
- **Es certificable:** Permite a una empresa demostrarles a sus clientes que sus datos están protegidos bajo estándares estrictos.
- **Define los controles:** Dice exactamente qué medidas aplicar (políticas, claves, firewalls, respaldos) para mitigar riesgos.

4. ¿Qué es IEC?

IEC son las siglas de **Comisión Electrotécnica Internacional** (*International Electrotechnical Commission*).

Es el organismo mundial que crea estándares internacionales para todas las tecnologías **eléctricas y electrónicas**.

En resumen:

- **¿Por qué aparece junto a la ISO?** Porque la **ISO** (procesos/gestión) e **IEC** (tecnología/hardware) se unieron para crear estándares informáticos juntos.
- **Nombre completo de la norma:** Por eso la norma oficial se llama **ISO/IEC 27001**

5. ¿Por qué el SGSI es el PDCA?

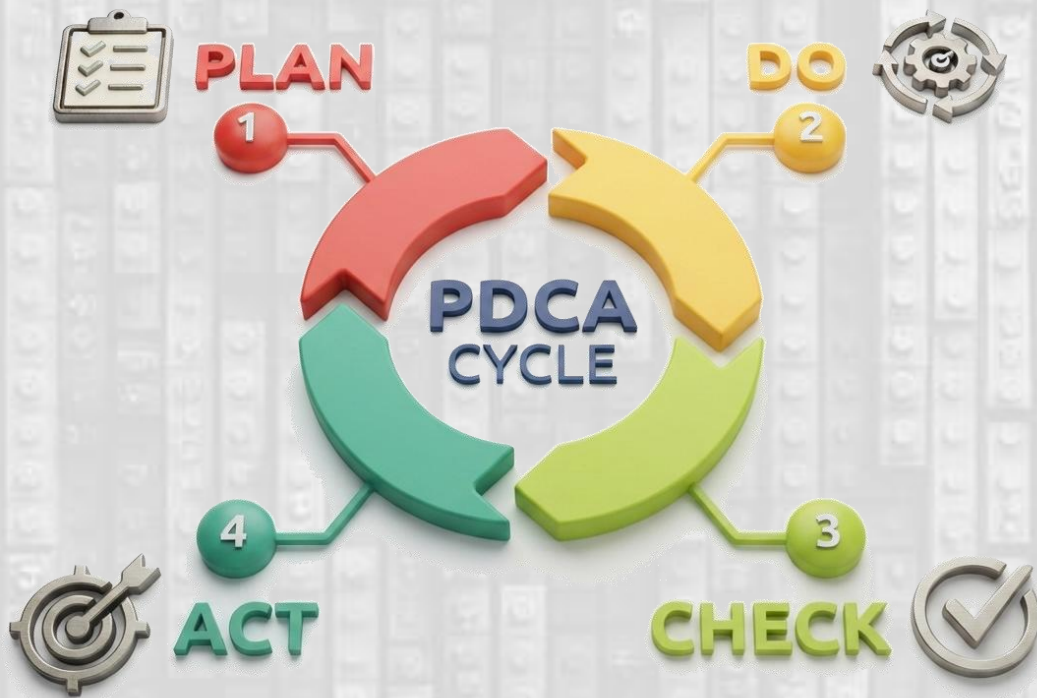
Si bien la pregunta es un concepto se refiere al carácter práctico del SGSI; un SGSI no es un documento **ESTÁTICO**, es un **PROCESO** en movimiento que **NUNCA TERMINA**.

Dicho de otra forma, un SGSI no utiliza PDCA como un método adicional que se agrega. **La propia estructura de cláusulas de ISO/IEC 27001:2022 es el ciclo Plan-Do-Check-Act**. Cada cláusula de la norma corresponde a una fase:

Fase	Cláusulas ISO 27001:2022	Qué se responde en esta fase
Plan	4. Contexto	¿Qué vamos a proteger, contra qué, y con qué política?
	5. Liderazgo	
	6. Planificación	
Do	7. Soporte	¿Cómo ejecutamos lo planificado?
	8. Operación	
Check	9. Evaluación del desempeño	¿Está funcionando lo que implementamos?
Act	10. Mejora	¿Qué corregimos, y cómo alimenta esto al próximo ciclo?

Llevado a un escenario real sería así:

Fase PDCA	Cláusula ISO	Acción en la vida real
Plan	4, 5 y 6	Analizas tu barrio y decides poner alarmas y rejas porque hay robos.
Do	7 y 8	Instalas las alarmas, pones las rejas y le enseñas a tu familia a activarlas.
Check	9	Revisas las cámaras un mes después y te das cuenta de que la alarma trasera no suena bien.
Act	10	Reparas la alarma trasera y compras un sensor extra. Esa mejora vuelve al paso "Plan" para el próximo año.



La idea central que hay que retener: **el ciclo no es lineal, es circular**. La salida de Act no es un punto final, es la entrada del siguiente Plan. Un SGSI que "termina" en Act sin retroalimentar el Plan no está haciendo gestión continua, está haciendo un proyecto de una sola vez y eso es exactamente lo que ISO 27001 no quiere.

A continuación, cada fase explicada y aterrizada en el caso ficticio de Clínica Jaguar Salud.



6. Plan (Planificar)

En esta etapa:

- Definir el contexto de la organización.
- Obtener el compromiso de la dirección.
- Establecer el alcance del SGSI.
- Fijar la Política General de Seguridad de la Información
- Identificar los activos de información.
- Evaluar los riesgos que los amenazan.
- Decidir cómo tratarlos.
- Declarar qué controles del Anexo A de la ISO 27001 aplican (Declaración de Aplicabilidad o SoA).

Todo esto ocurre **antes** de tocar un solo control técnico.

Cómo se ve en Clínica Jaguar Salud:

- **Alcance:**
 - Historia clínica electrónica y PACS.
 - Sistema de gestión de citas.
 - ERP financiero/RRHH.
 - Base de datos de pacientes, personal médico/administrativo/TI.
 - Infraestructura física y digital.
 - Quedan fuera dispositivos personales no registrados.
- **Activos críticos identificados:**
 - Inventario CIA: Historia clínica electrónica (Alta/Alta/Alta)
 - Base de datos de pacientes
 - Sistema ERP
 - Resultados de exámenes (PACS)

Pipe PDCA ISO27001 SGSI SMART| 6. Plan (Planificar)

- Respallos automáticos
- Consentimientos informados digitalizados; todos etiquetados Crítico – Nivel 1 o Alto – Nivel 2.
- **Riesgos evaluados** (Impacto **x** Probabilidad, escala ISO 27005):

Riesgo	I	P	Valor	Nivel
Ransomware en historia clínica	3	3	9	Crítico
Falta de respaldo validado	3	3	9	Crítico
Fuga por error humano (correo)	3	2	6	Moderado
Uso de contraseñas compartidas	2	2	4	Moderado

- **Políticas definidas:**
 - Política General del SGSI.
 - Control de acceso e identidades.
 - Gestión de incidentes.
 - Continuidad del negocio

todas ancladas a:

- Ley 19.628 (datos personales).
- Ley 20.584 (derechos del paciente).
- Ley 21.668 (conservación de fichas clínicas).

- **SoA parcial**

De 8 controles seleccionados, la mayoría parte en estado **"no implementado"** o **"parcialmente implementado"**.

(ej: A.8.5 Autenticación segura: contraseñas compartidas, sin MFA).

El desarrollo correcto de la fase Plan nos deja listo un mapa que nos indica claramente:

- qué proteger
- con qué prioridad (según el valor de riesgo)
- con qué controles

pero todavía nada de esto está en operación. Eso es tarea de la siguiente fase, Do.



7. DO (Hacer)

Ejecutar lo planificado. Aquí se implementan

- Controles técnicos
- Se capacita al personal
- Se despliegan las políticas
- Se pone en marcha el cronograma.

Es la fase de "manos a la obra" y también la que **genera los datos** que la fase Check necesitará para medir si algo sirvió.

Cómo se ve en Clínica Jaguar Salud:

- **8 controles del Anexo A implementados**, uno por categoría relevante:
 - **Organizacionales:**
 - A.5.1 (Política de seguridad).
 - A.5.24 (Gestión de incidentes).
 - **Personas:**
 - A.6.3 (Concienciación).
 - A.6.5 (Responsabilidades post-empleo).
 - **Físicos:**
 - A.7.1 (Perímetros de seguridad física)
 - A.7.4 (Vigilancia física).
 - **Tecnológicos:**
 - A.8.3 (Restricción de acceso)
 - A.8.16 (Monitoreo de actividades).

- **Cronograma trimestral (12 meses ejemplo):**

Trimestre	Actividad principal
T1	Diagnóstico de necesidades y análisis de contexto
T2	Gestión de riesgos y redacción de políticas iniciales
T3	Implementación técnica (MFA, respaldos, control de accesos) y formación por perfil
T4	Auditoría interna y revisión de mejora continua

- **Capacitación por perfil:**

- Taller práctico para personal médico ("Protegiendo la historia clínica")
- Charla para personal administrativo (gestión de citas y facturación)
- Workshop técnico para TI (controles ISO 27001:2022).

- **Presupuesto ejecutado (T1-T2):** ~\$8.9 millones CLP, incluyendo software de respaldo, licencias MFA y formación interna.

Lo que deja listo para la siguiente fase

- Controles operando
- Personal capacitado
- Flujo de datos reales (logs de acceso, resultados de restauración, asistencia a capacitaciones, tickets de incidentes) que antes no existía. Sin este flujo, Check no tendría nada que medir.

8. Check (Verificar)

Medir si lo implementado en Do realmente está funcionando, comparar contra los umbrales definidos en Plan, y sacar a la luz las brechas. Esta fase **no corrige nada todavía solo diagnostica con evidencia.**

Cómo se ve en Clínica Jaguar Salud:

- KPIs monitoreados mensualmente:

Indicador	Valor de referencia
% de respaldos restaurables exitosos	$\geq 95\%$
% de usuarios con MFA activo	$\geq 95\%$
Tiempo promedio de resolución de incidentes	≤ 24 horas

- Evolución trimestral real detectada:

Trimestre	% MFA activo	% éxito restauración	Incidentes no reportados
T1	36%	0%	36
T2	60%	25%	18
T3	78%	75%	12

Hallazgos críticos que surgen de esta medición:

- Solo 60% de usuarios con MFA en T2 (muy bajo el umbral de 95%).
- Falla total de restauración de respaldos en T1.
- 12 incidentes sin reportar en T3; evidencia de una cultura de reporte débil.

Mapa de calor de riesgos:

Cruce de activos críticos vs. controles, que visualiza que la Historia Clínica Electrónica es el activo con mayor exposición, principalmente por las no conformidades de capacitación y reporte detectadas en la auditoría interna.

Lo que deja listo para la siguiente fase

Una lista concreta de brechas con causa raíz identificada (ej: "12 incidentes no reportados > ausencia de cultura de reporte").

Estos hallazgos son inútiles si se quedan solo como diagnóstico por lo tanto necesitan convertirse en acción. Eso es la siguiente fase, Act.



9. Act (Actuar)

Convertir cada hallazgo de Check en una acción correctiva concreta, medible y con plazo (criterios SMART), actualizar la documentación del SGSI que quedó obsoleta frente a la evidencia, y decidir si el ciclo se cierra o si algo debe reevaluarse en el próximo Plan.

Los **criterios SMART** son una regla o marco de trabajo para definir las acciones correctivas de forma clara y realizable, asegurando que no queden en intenciones vagas.

Cada sigla corresponde a una característica de la acción:

- **S (Specific):** Define **exactamente** qué se va a hacer (ej. "Activar MFA obligatorio" en lugar de "Mejorar la seguridad").
- **M (Measurable):** Permite **verificar** su cumplimiento mediante un indicador o meta concreta (ej. "≥90% de personal aprobado").
- **A (Achievable):** Es una meta **realista y realizable** según las capacidades de la organización.
- **R (Relevant):** Resuelve directamente la **causa raíz** del hallazgo encontrado en la fase de verificación (CHECK).
- **T (Time-bound):** Tiene una fecha o **plazo límite** establecido para su ejecución (ej. "Plazo de 60 días").

En resumen, sirven para transformar los problemas detectados en la auditoría en **tareas concretas, asignadas y con un tiempo límite claro**.

Cómo se ve en Clínica Jaguar Salud:

Hallazgo (de Check)	Acción correctiva SMART	Plazo
Solo 60% con MFA (T2)	Activar MFA obligatorio en todo el personal crítico	60 días
Restauración falló en prueba (T1)	Verificación automatizada diaria de respaldos	Inicio inmediato, mensual
Baja cultura de capacitación	Taller + evaluación obligatoria, $\geq 90\%$ aprobado	90 días
12 incidentes no reportados (T3)	Canal de reporte anónimo vía intranet	30 días

Actualización documental derivada:

- la Política de Control de Acceso se modifica para exigir MFA obligatorio y prohibir contraseñas compartidas
- el Procedimiento de Gestión de Incidentes se actualiza con clasificación por severidad (crítico 4h / medio 24h / bajo 72h) y canal anónimo.

Responsables y gobierno del cambio:

- matriz RACI que define que el RSI es quien ejecuta y valida
- Dirección aprueba los cambios de política
- TI y RRHH son consultados según la acción.

Actividad	RSI	TI	RRHH	Dirección
Activar MFA obligatorio en personal crítico	A	R	I	I
Verificación automatizada diaria de respaldos	C	R	I	I
Taller y evaluación obligatoria de capacitación	C	I	R	I
Implementar canal de reporte anónimo	R	C	I	I
Actualizar Política de Control de Acceso	R	C	I	A
Actualizar Procedimiento de Gestión de Incidentes	R	C	I	A

R = Responsable (ejecuta) · A = Aprobador (última palabra) C = Consultado · I = Informado

El cierre del ciclo:

Estas políticas actualizadas y estos nuevos controles no son el final, son el nuevo punto de partida.

La próxima vez que se ejecute Plan, el alcance ya no parte de "0% con MFA" sino de la política ya corregida; el próximo Check medirá contra este nuevo estándar.

Así es como un SGSI mejora de verdad: no reescribiéndose desde cero cada vez, sino ajustando lo que la evidencia mostró que fallaba.



10. El ciclo cerrado

Lo que hace que esto sea "mejora continua" y no un proyecto con fecha de término es precisamente esa flecha de vuelta: **Act no cierra el SGSI, lo reinicia con un estándar más alto**. Cada vuelta del ciclo, el listón de lo "aceptable" (ver tabla de categorización: Crítico <70%, Alto <85%, Aceptable <95%, Óptimo $\geq 95\%$) se vuelve más exigente porque ya se corrigieron los problemas más evidentes de la vuelta anterior.



Esa es la diferencia real entre "implementar un SGSI" (un evento) y "gestionar la seguridad de la información" (un proceso que no termina).

Conclusión

La gestión de la seguridad de la información en las organizaciones actuales no puede concebirse como un proyecto estático ni como una meta con fecha de término; es un compromiso operativo continuo. A lo largo de este documento, ha quedado demostrado que el valor real de la norma ISO/IEC 27001 radica en su alineación intrínseca con el ciclo PDCA, transformando la ciberseguridad en un proceso dinámico de adaptación y resiliencia.

La aplicación práctica en el caso de la *Clínica Jaguar Salud* ilustra cómo la teoría metodológica se traduce en decisiones estratégicas y técnicas concretas: desde la identificación rigurosa de activos y riesgos en la fase **Plan**, pasando por el despliegue de controles y formación en **Do**, la medición objetiva mediante evidencias en **Check**, hasta la ejecución de acciones correctivas SMART en **Act**.

En definitiva, cerrar el ciclo no significa finalizar la gestión, sino elevar el nivel de madurez de la organización para el siguiente ciclo de planificación. Adoptar un SGSI bajo esta perspectiva garantiza que la seguridad de la información deje de ser un simple requisito normativo y se convierta en un pilar fundamental de confianza, continuidad operativa y valor estratégico para la organización.



SGSI
Sistema de Gestión de la
Seguridad de la Información

